

IT / Security / Compliance Validation Pack

Hawkeye Go-To-Market Pack · 2026-04-26

Hawkeye — IT / Security / Compliance Validation Pack

Track B · for IT / Security / DPO / Compliance reviewers. Designed to answer the questions you're going to ask. Pair with Doc 6a (Executive One-Pager) for the business value side.

Document purpose

This pack answers the questions a buyer's IT / Security / Compliance / DPO team asks during procurement:

- "Where does our data live?"
- "What are your authentication controls?"
- "Can our LLM calls go through our VPC?"
- "How does e-signature comply with 21 CFR Part 11?"
- "What's your SOC 2 / ISO 27001 / HIPAA / GxP posture?"
- "Can we run this on-prem?"

Each section is structured: **Question** → **Hawkeye Answer** → **Evidence we can provide**.

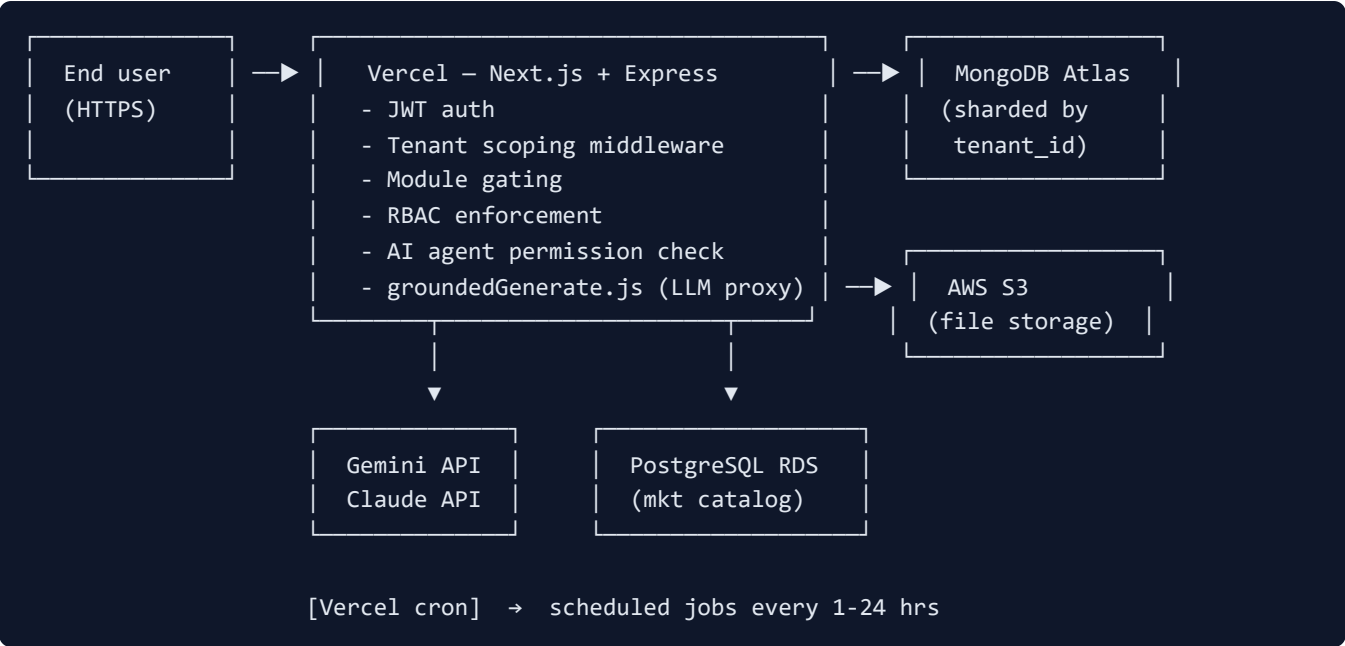
1. Architecture overview

1.1 What is Hawkeye, technically?

Hawkeye is a multi-tenant SaaS application built on:

- **Frontend:** Next.js 14 (TypeScript), deployed on Vercel.
- **Backend:** Node.js / Express, deployed as Vercel serverless functions.
- **Primary data store:** MongoDB Atlas (multi-tenant, sharded by `tenant_id`).
- **Marketplace catalog:** PostgreSQL on AWS RDS (multi-tenant via row-level isolation).
- **File storage:** AWS S3 (per-tenant bucket prefix; SSE-S3 at rest).
- **Background jobs:** Vercel cron (scheduled HTTPS triggers with shared secret).
- **AI agents:** REST calls to Google Gemini API (default) and Anthropic Claude API (premium).

1.2 Architecture diagram (logical)



1.3 Data flow — what crosses what trust boundary

Flow	Where it goes	Authentication	Encryption
Browser → app	Vercel	JWT in Authorization header	TLS 1.3
App → MongoDB	MongoDB Atlas	mTLS client cert + IP allow-list	TLS 1.3 + at-rest AES-256
App → S3	AWS S3	IAM role-assumed (no static keys)	TLS 1.3 + SSE-S3 (AES-256)
App → LLM (Gemini/Claude)	Google / Anthropic	API key via Vercel env (rotated quarterly)	TLS 1.3
App → external integrations	Customer-owned endpoints	Customer-provided OAuth / mTLS / API key	TLS 1.3
Cron → app	Vercel cron → app endpoint	Bearer token (shared secret, rotated)	TLS 1.3

2. Authentication & Authorization

2.1 User authentication

- **Today:** JWT-based (HS256), 15-min access token + 7-day refresh token. Passwords hashed with bcrypt (cost factor 10).
- **MFA:** TOTP-based MFA available; tenant_admin can enforce MFA for all users.
- **SSO:** SAML 2.0 + OIDC (roadmap Q3 2026; design partner-driven).
- **SCIM:** User provisioning auto-sync (roadmap Q4 2026).
- **Session management:** Refresh-token rotation; idle timeout configurable per tenant (default 30 min).

2.2 Authorization (RBAC)

- **Role-based** with industry-pack defaults (12-15 roles per pack).
- **Module gating** — modules can be disabled per tenant; users with no permission see nothing.
- **Custom-role builder** (Phase 2) — `tenant_admin` defines new roles with allow/deny per module action.
- **Audit log** — every permission change recorded (who, when, old, new, reason).

2.3 Service-to-service

- **MongoDB**: mTLS client cert (rotated quarterly), IP allow-list (Vercel egress IPs only).
 - **AWS S3**: IAM role assumed by Vercel function execution role; no static credentials.
 - **External LLM**: API key in Vercel encrypted env var; provider-side IP allow-list where supported.
-

3. Data residency & isolation

3.1 Where data lives (SaaS default)

- **MongoDB Atlas**: AWS `us-east-1` (default) or `eu-west-1` (EU customers). Customer can request region at contract.
- **S3**: Same region as MongoDB.
- **PostgreSQL (marketplace)**: AWS `us-east-1`.
- **Vercel functions**: Auto-region routed; all DB calls hit assigned region.

3.2 Multi-tenant isolation

- **MongoDB**: every collection has `tenant_id` field; every query is wrapped by `tenantScope` middleware that enforces the filter at query-build time. **No raw-query path bypasses this** — controllers use the wrapped query API only.
- **S3**: per-tenant bucket prefix `s3://hawkeye-prod/<tenantId>/...`; IAM policy denies cross-tenant access.
- **Marketplace Postgres**: row-level security (RLS) enforced at the connection level.

3.3 Cross-tenant data (where it exists)

The only data that intentionally crosses tenants:

- **Marketplace catalog** (supplier profiles, audit reports licensed for sharing) — opt-in per supplier.
- **Anonymized observation patterns** (Wave-2 AI agent training corpus) — opt-out at tenant level; PII stripped pre-aggregation.

For customers who require zero cross-tenant data: **Private Cloud or On-prem deployment** (see Doc 3) physically separates everything.

4. Encryption

4.1 In transit

- **All HTTP**: TLS 1.3 (TLS 1.2 supported for legacy clients).
- **Internal**: TLS for every DB / S3 / external API call. No plaintext within the network.

4.2 At rest

- **MongoDB Atlas:** AES-256 GCM encryption-at-rest, customer-managed keys (CMK) available on Private Cloud.
- **S3:** SSE-S3 (AES-256) default; SSE-KMS with customer-managed CMK on Private Cloud.
- **PostgreSQL:** AES-256 storage encryption.
- **Vercel function code:** not at-rest sensitive; secrets stored in encrypted env vars.

4.3 Key management

- **SaaS:** Vercel env (encrypted), MongoDB Atlas-managed keys, AWS-managed S3 keys.
- **Private Cloud:** Customer's AWS KMS / Azure Key Vault, Hawkeye uses but never exports.
- **Key rotation:** API keys rotated quarterly; DB credentials rotated semi-annually; S3 bucket policies reviewed annually.

5. AI / LLM controls

This is where IT teams ask the hardest questions. Honest answers:

5.1 Where prompts go (SaaS default)

- All LLM prompts go to Google (Gemini) or Anthropic (Claude) public API endpoints over TLS.
- **Both Google and Anthropic contractually agree they do not train on Hawkeye's API traffic** (Vertex AI / Anthropic API terms).
- Prompts may include tenant content (audit findings, supplier names, document excerpts).
- Responses are stored in MongoDB as part of the agent-usage-event record (for ROI calculation and audit trail).

5.2 PII / PHI handling

- **By default**, no PHI/PII redaction is performed before LLM calls.
- For tenants with PHI/PII concerns, **Hybrid deployment** (Doc 3) provides a PII Redaction Proxy that runs in customer's VPC.
- For tenants with absolute restrictions, **On-prem deployment** with on-prem LLM (Llama 70B / Mixtral / Qwen) eliminates external LLM calls entirely.

5.3 Per-call governance

- **Permission matrix** (Doc 4 §2.6) — which roles can call which agents.
- **Per-user / per-role / per-tenant quotas** — daily, monthly, \$-cap.
- **Audit log** — every agent invocation (`agent-usage-event` record): who · when · agent · prompt-hash · cost · outcome · grounded citations.
- **Tenant admin can disable any agent globally** at any time.
- **Bring-your-own LLM key** (Tier C) — customer's Gemini/Anthropic account, customer pays directly, Hawkeye never sees the key beyond runtime use.

5.4 Prompt injection / safety

- **Output validation:** structured-output enforcement (JSON schema) on every agent.
- **Citations required** for grounded agents (Audit Report Assembler, Supplier-Intel, Ask Hawk RAG).
- **Confidence threshold:** agents auto-block low-confidence outputs.

- **Human-in-the-loop:** every AI output requires user accept/discard before persisting to records.

6. Compliance posture

6.1 Today

Control	Status	Evidence
21 CFR Part 11 §11.50 (e-signatures)	✅ enforced via <code>requireESignature</code> middleware (configurable: hard/soft/off). Captures content-hash, signer IP, user-agent, signature meaning.	Demo + middleware code review
21 CFR 314.81 (Field Alert Reports)	✅ Auto-clock on critical deviations (3-day FAR clock)	Code + audit-log evidence
21 CFR 803 (Medical Device Reports)	✅ Auto-clock on complaints (5/15/30 day)	Code + audit-log evidence
EU GMP Annex 11 (computerized systems)	⚠ partial — system documentation drafted, validation reports pending Q3 2026	Doc package on request
GxP audit trail	✅ universal <code>audit-trails</code> collection captures every state-change with before/after snapshot, actor, IP, UA	DB schema + sample audit-trail export
GDPR / EU data residency	✅ EU region option; SCCs available; right-to-erasure workflow	DPA template
HIPAA BAA	⚠ available on Hybrid + Private Cloud only (Q4 2026)	BAA template
SOC 2 Type II	⚠ Type I complete; Type II audit Q3 2026, report Q1 2027	Type I report on NDA
ISO 27001	⚠ Pre-cert audit Q4 2026	Gap-analysis report on NDA

6.2 Roadmap

Quarter	Compliance milestone
Q3 2026	SOC 2 Type II audit complete · EU GMP Annex 11 validation report · SAML SSO GA
Q4 2026	HIPAA BAA available on Hybrid / Private Cloud · ISO 27001 pre-cert
Q1 2027	SOC 2 Type II report public · ISO 27001 cert · FDA QMSR pack live (med-device)
Q2 2027	First on-prem airgapped customer (validation reports per customer)

7. Audit trail — what we capture

Every state-changing action in the system writes to `audit-trails` (universal log). Sample event:

```
{
  "tenantId": "acme-pharma",
  "userId": "5f3...",
  "userRole": "audit_lead",
  "action": "AUDIT_CLOSED",
  "entityType": "audit-requests-master",
  "entityId": "69ee...",
  "previousState": { "trackStatus": "CAPA Submission Awaited", "facilityOutcome": null },
  "newState": { "trackStatus": "Audit Closed", "facilityOutcome": "SATISFACTORY" },
  "ip": "203.0.113.45",
  "userAgent": "Mozilla/5.0 ...",
  "electronicSignatureId": "...",
  "createdAt": "2026-04-26T14:33:21.044Z"
}
```

Retention: 24 months hot, 7 years archived to S3 Glacier (Part 11 / SOX-compliant retention period).

Customer access: Tenant_admin can search/export audit trail in the Admin Panel; full export via API.

Tamper-evidence: Audit-trail rows are append-only; no DELETE/UPDATE allowed at MongoDB schema level.

8. Vulnerability & incident management

- **Dependency scanning:** GitHub Dependabot + Snyk on every PR; critical CVEs SLA: 7 days.
- **Container scanning:** Image scanning via AWS ECR for any custom containers.
- **Pen-test:** Annual third-party pen-test (next: Q3 2026); reports available under NDA.
- **Vulnerability disclosure:** security@hawkeye.app (PGP key on website); 90-day responsible disclosure window.
- **Incident response:**
 - 24/7 paging for P0 (data breach / availability outage).
 - Customer notification within **24 hours** for any confirmed data incident.
 - Post-mortem published within 5 business days.
- **DR/BCP:** MongoDB Atlas continuous backups + cross-region replication; RPO 1 hour, RTO 4 hours.

9. Subprocessors

Subprocessor	Purpose	Data shared
Vercel Inc.	Application hosting	All app traffic
MongoDB Inc. (Atlas)	Primary data store	All tenant transactional data
Amazon Web Services	S3 file storage, RDS for marketplace	File uploads, marketplace catalog
Google LLC (Vertex AI)	LLM provider for AI agents	Prompts + responses for agent calls
Anthropic PBC	LLM provider for premium agents	Prompts + responses for premium agent calls
Stripe (or equiv.)	Billing	Tenant billing metadata, no transactional data

Customer can require restriction (e.g., no Anthropic) — Hawkeye configures their tenant to use Gemini only.

10. On-prem deployment — IT-team validation summary

For airgapped on-prem (full detail in Doc 3):

- **Hawkeye app code** is identical to SaaS; ships as Docker images + Helm chart.
 - **LLM serving stack** customer's choice: vLLM (recommended) / Ollama / TensorRT-LLM.
 - **Recommended models**: Llama 3.1 70B Instruct · Mixtral 8x22B · Qwen 2.5 72B (China/Asia-region).
 - **Hardware sizing reference**: 1× NVIDIA A100 80GB minimum (single tenant, 50 users); 2× A100 for production.
 - **No customer data egresses** the customer's network (true airgap supported).
 - **Public regulatory intel** (openFDA, EMA EudraGMDP) shipped as a quarterly-updated bundled DB.
 - **Marketplace** is inbound-only (customer can sync supplier-master from Hawkeye cloud, cannot publish into it).
 - **Update cadence** customer-controlled; Hawkeye delivers signed Helm charts quarterly.
-

11. The questions IT teams ask (FAQ)

Q: Can we use our own SSO (SAML/OIDC)? A: Yes for SAML 2.0 (Q3 2026 GA); OIDC right after. Today: JWT only.

Q: Can we get a SOC 2 Type II report? A: Type I available now under NDA; Type II report Q1 2027.

Q: Are LLM prompts trained on? A: No. Both Google Vertex AI and Anthropic API contractually agree no training on API traffic. Verifiable in their terms.

Q: Can we audit every LLM call? A: Yes. `agent-usage-events` collection captures every call with prompt hash + outcome + tokens + cost. Tenant_admin can export.

Q: What if your LLM provider has an outage? A: Each agent has a fallback provider configured. If both fail, the agent UI tells the user "AI unavailable, do this manually."

Q: Can we run completely without LLMs? A: Yes — all features work without AI; AI is additive. Tenant_admin can disable every agent globally.

Q: Where do you store our SOPs / batch records / patient data? A: MongoDB Atlas (transactional) + S3 (files). For PHI/PII concerns, use Hybrid (PHI never leaves your VPC) or On-prem (full airgap).

Q: How long do you retain our data after contract termination? A: 90-day grace period (you can export); then full deletion within 30 days. Audit trail retained per regulatory requirement (longer of regulatory minimum or contract term).

Q: Do you have a Data Processing Agreement (DPA)? A: Yes — standard DPA + EU SCCs available; custom DPA negotiable on Private Cloud / On-prem.

Q: What's your uptime SLA? A: SaaS: 99.5% (commercial); 99.9% on Private Cloud + premium tier; on-prem: customer-managed.

Q: Can we self-host? A: Yes — see Doc 3 for the deployment models and on-prem reference architecture.

12. Procurement next steps

1. **NDA executed** — we share SOC 2 Type I + pen-test summary + sample DPA.
2. **Architecture review (60 min)** — IT/Security walks through this doc with our CTO.
3. **Technical pilot (30 days)** — sandbox tenant, your IT team validates.
4. **Procurement** — choose deployment tier; sign MSA + DPA; production tenant provisioned in 5 business days for SaaS, 4-8 weeks for Private Cloud, 8-16 weeks for On-prem.

Contact: security@hawkeye.app · NDA template: hawkeye.app/legal/nda · Compliance evidence room: hawkeye.app/trust